CONFIDENTIAL SECURITY DOCUMENT

Dependency & Supply-Chain Risk Assessment

Example Corp — Example Application Dependency Tree

SBOM-based third-party risk review

Document Type	Software Bill of Materials (SBOM) based dependency risk review
Application	[FILL: name / repo]
Assessment Date	1 January 2030
Total Dependencies	[FILL: N (direct + transitive)]
Findings	[FILL: N (n Critical, n High, n Medium, n Low)]
Classification	**Confidential — Restricted Distribution**

Distribution: This document contains sensitive security information and must not be shared outside authorised personnel responsible for remediation.

Scope of analysis: [FILL: One or two sentences, e.g. "an SBOM was generated from the application's lockfiles and scanned against public vulnerability and license databases; direct and transitive dependencies were both in scope."]

1

1 Table of Contents

2 Executive Summary 2
2.1 Overview . . . 2
2.2 Findings by Severity . . . 2

3 Scope & Methodology 3
3.1 Subject & Scope . . . 3
3.2 Approach . . . 3
3.3 Severity Definitions . . . 3

4 SBOM Inventory 4
4.1 Notable Components . . . 4

5 Findings Catalogue 5
5.1 F-01 — [FILL: e.g. "Known RCE in a Directly-Used Serialization Library"] 5
5.2 F-02 — [FILL: e.g. "Unmaintained Dependency With No Security Support"] 5

6 Recommendations 6

7 Appendix A — Tools Used 7

8 Appendix B — Full SBOM Pointer 7

2 Executive Summary

Overview

A Software Bill of Materials (SBOM) was generated for Example Corp — Example Application Dependency Tree and its dependency tree was assessed for known vulnerabilities, license risk, and maintenance/supply-chain health.

[FILL: One or two sentences on the overall outcome, e.g. "the application depends on N end-of-life packages with known RCE CVEs, and M packages have had no maintainer activity in over two years."]

CRITICAL — Key Takeaway

Result — [FILL: one-line verdict].

Headline conclusions:

- [FILL: Headline finding 1]
- [FILL: Headline finding 2]

Findings by Severity

Severity	Count	Meaning
CRITICAL	[FILL: n]	[FILL: e.g. known unauthenticated RCE in a directly-reachable dependency]
HIGH	[FILL: n]	[FILL: e.g. known high-severity CVE, no patch available]
MEDIUM	[FILL: n]	[FILL: e.g. end-of-life package, no known CVE yet]
LOW	[FILL: n]	[FILL: e.g. license risk, low download/maintainer activity]

3 Scope & Methodology

Subject & Scope

Item	Detail
Application/repo	[FILL: name]
Ecosystems covered	[FILL: e.g. npm, PyPI, Maven, Go modules]
SBOM format	[FILL: e.g. CycloneDX / SPDX]

Approach

1. **SBOM generation.** Generate a full dependency tree (direct + transitive) from the project's lockfiles/build manifests.
2. **Vulnerability matching.** Match each component/version against public vulnerability databases (NVD, GHSA, OSV) for known CVEs.
3. **License review.** Flag components under licenses incompatible with the organisation's distribution model (e.g. copyleft licenses in a proprietary product).
4. **Health/maintenance review.** Flag components that are unmaintained, deprecated, or have a history of supply-chain incidents (e.g. a prior compromised release).
5. **Reachability analysis.** Where feasible, determine whether the vulnerable code path is actually reachable/exercised by the application, to separate "present" from "exploitable."

Severity Definitions

Level	Definition
CRITICAL	Known, reachable, unauthenticated RCE or equivalent in a used dependency.
HIGH	Known high-severity CVE with no patch, or a patch not yet applied.
MEDIUM	End-of-life component with no current CVE, or an unreachable known CVE.
LOW / Info	License risk, low maintenance activity, or hygiene gaps.

4 SBOM Inventory

Metric	Value	Notes
Direct dependencies	[FILL: n]	—
Transitive dependencies	[FILL: n]	—
Components with a known CVE	[FILL: n]	[FILL: note]
End-of-life / unmaintained components	[FILL: n]	[FILL: note]
Components with incompatible license	[FILL: n]	[FILL: note]

Notable Components

Component	Version	Severity	Issue
[FILL: package-name]	[FILL: x.y.z]	CRITICAL	[FILL: CVE-YYYY-NNNNN - one-line description]
[FILL: package-name]	[FILL: x.y.z]	MEDIUM	[FILL: End-of-life since <date>, no CVE yet]

5 Findings Catalogue

F-01 — [FILL: e.g. "Known RCE in a Directly-Used Serialization Library"]

Finding Metadata			
ID	F-01	**Severity**	CRITICAL
Component	[FILL: package-name@version	**CVE**	CVE-YYYY-NNNNN

[FILL: Description of the vulnerability, whether the vulnerable code path is reachable from this application, impact, and remediation (upgrade path / patch availability).]

F-02 — [FILL: e.g. "Unmaintained Dependency With No Security Support"]

[FILL: Description, impact, and remediation.]

6 Recommendations

Priority	Recommendation
Immediate	[FILL: e.g. upgrade the affected serialization library to the patched version]
Short-term	[FILL: e.g. replace unmaintained packages with actively-supported alternatives]
Long-term	[FILL: e.g. add automated SBOM generation + vulnerability scanning to CI]

7 Appendix A — Tools Used

- [FILL: e.g. Syft (SBOM generation), Grype/Trivy (vulnerability scanning), FOSSA (license scanning)]

8 Appendix B — Full SBOM Pointer

[FILL: Note where the full machine-readable SBOM (CycloneDX/SPDX JSON) can be found.]